

Shellshock 漏洞（CVE-2014-6271）分析报告

漏洞概述

Shellshock（又称 **Bashdoor** 或 “Broken Bash”）是 2014 年 9 月中旬由法国安全研究员 Stéphane Chazelas 发现并于 2014 年 9 月 24 日向公众披露的 GNU Bash 远程代码执行漏洞^{1 2}。受影响的 Bash 版本包括 1.03 到 4.3（包括 Mac OS X 自带的 3.2.x 版本）^{1 3}。该漏洞极其严重：美国国家漏洞数据库（NVD）评估其 CVSS v2.0 基础分为 **10.0**（最高等级 High），CVSS v3.1 基础分为 **9.8**（Critical）^{4 5}。安全界普遍认为 Shellshock 的影响范围可与 2014 年 4 月发现的 Heartbleed 漏洞相提并论⁶。漏洞编号主要为 CVE-2014-6271，后续又衍生出多个关联的 CVE（如 CVE-2014-7169、CVE-2014-6277/6278、CVE-2014-7186/7187 等）⁷。该漏洞允许攻击者通过精心构造的环境变量在 Bash 中执行任意命令，从而可能在服务器上获取最高权限^{2 8}。

技术细节

Shellshock 漏洞根源于 Bash 处理环境变量中**函数定义**的方式。Bash 允许通过环境变量导出函数，例如：

```
export FUNC='() { echo hello; }'
```

在正常情况下，这会在新启动的子 Shell 中定义一个名为 `FUNC` 的函数。但 Shellshock 漏洞在于 Bash 对这种定义后的后续内容处理不当：如果环境变量值以 `() {}` 开头定义了一个函数，Bash 将**继续执行**这一定义后面的任意字符串^{2 9}。例如：

```
env X='() { :;; }; /usr/bin/id' bash -c "echo done"
```

在易受攻击的 Bash 中，`X` 被解析为一个空函数定义后，紧接着的 `/usr/bin/id` 被执行，从而打印了当前用户信息。正如 NVD 所描述：“**GNU Bash through 4.3 processes trailing strings after function definitions in the values of environment variables, which allows remote attackers to execute arbitrary code via a crafted environment**”²。此处关键问题是 Bash 在导入环境变量中的函数定义时，未能严格隔断函数体边界导致的解析缺陷⁹。简而言之，攻击者只需创建形如

`VAR='() { :;; ; <恶意命令>'` 的环境变量并触发 Bash 执行，Bash 就会先定义一个空函数，再执行 `<恶意命令>`^{2 9}。漏洞的核心原因在于输入过滤不严谨，缺乏对函数定义后附加内容的有效验证⁹。360 安全团队分析指出，该漏洞利用了 Bash **环境变量的不当处理**，攻击者可以隐蔽地执行任意代码，有可能获得系统最高权限⁸。

利用方式

Shellshock 漏洞被广泛用于远程攻击，主要手法是将恶意命令注入到传递给 Bash 的环境变量中。常见攻击矢量包括：

- **Web CGI 注入**：当 Web 服务器（如 Apache、nginx 等）使用 CGI/Perl/PHP 脚本时，HTTP 请求头（如 `User-Agent`、`Referer`、`Host`）和 GET/POST 参数会被导入为环境变量。攻击者可在这些头字段中嵌入 `() { :;; ; <命令>`。CloudFlare 安全团队监测到有攻击者在 `User-Agent` 字段中注入类似 `() { :;; ; /bin/eject` 的字符串，并通过发起如 `curl -H "User-Agent: () { :;; ; /bin/eject" http://example.com/` 的请求来触发命令执行¹⁰。例如，该示例可在易受攻击服务器上弹出 CD 驱动盒，从而证明漏洞存在¹⁰。

- **SSH 强制命令绕过**: 如果 SSH 服务器的某个公钥被配置了 `authorized_keys` 强制命令 (`command=...` 前缀), Shellshock 可用于绕过该限制。正如安全问答中所示, 将一个恶意函数定义加入到强制命令后面, 可使登录时执行强制命令之外的内容¹¹。例如, 攻击者可以在强制命令后追加 `'() { :;; <恶意命令>'`, 从而在成功认证并运行原定命令的同时执行额外代码¹¹。
- **DHCP 客户端攻击**: 部分使用 Bash 处理 DHCP 选项的客户端脚本 (如某些 Linux 发行版的 `dhcpcd`) 可能受影响。恶意 DHCP 服务器可以在响应中发送携带 `() { :;; <命令>` 的环境变量字段, 促使客户端在解析时执行代码² (NVD 报告提到 DHCP 客户端场景)。
- **其他应用程序**: 凡是用户可控输入作为环境变量传递给 Bash 的程序都可能被利用, 包括某些 SUID 脚本、网络设备管理接口等^{2 12}。

总之, 任何将外部数据导入 Bash 环境的入口都可能成为攻击载体, 常见实例包括 Web CGI (尤其是启用 `mod_cgi/mod_cgid` 的 Apache)、SSH 登录脚本以及自动化服务等^{2 10}。

影响范围

Shellshock 影响极为广泛, 几乎遍及所有默认安装 Bash 的 Unix-like 系统。具体而言:

- **操作系统平台**: 主流 Linux 发行版 (如 Red Hat、CentOS、Ubuntu、Debian、Fedora、Amazon Linux 等) 以及 macOS (10.4 以上版本默认包含 Bash) 都受影响^{13 3}。此外, 基于 Linux 内核的嵌入式系统和网络设备 (如部分路由器、物联网设备、网络安全设备等) 若使用 Bash 作为脚本解释器, 也会暴露风险^{13 12}。Windows 平台本身不内置 Bash (除非通过 Cygwin/WSL 等), 因此默认情况下不受影响³。
- **受影响软件/服务**: 任何将环境变量传递给 Bash 的服务都可能受影响。典型场景包括 Web 服务器的 CGI 模块、SSH 服务 (尤其是使用 Bash 作为登录 shell 或启用 ForceCommand 功能时)、DHCP 客户端脚本等^{2 13}。正如 NVD 所述, 攻击向量示例包括 OpenSSH 的 ForceCommand、Apache 的 `mod_cgi/mod_cgid`、DHCP 客户端脚本等²。据安天实验室和互联网安全分析, Shellshock 将严重影响网络基础设施安全, 包括网络设备、云服务、大数据中心等^{13 12}。由于 Bash 广泛分布且更新不易, 漏洞修复存在长尾风险, 有专家警告此漏洞可被恶意利用编写蠕虫实现自动传播, 形成大规模僵尸网络^{12 14}。如 360 安全研究员 redrain 所言, 只要设备连入互联网, 就可能受到 Shellshock 利用⁸。

修复措施

针对 Shellshock 漏洞, 各大厂商和发行版已在 2014 年 9 月下旬紧急发布了补丁:

- **官方补丁与升级**: GNU Bash 官方已提供修复补丁, 红帽、Debian、Ubuntu、Fedora、CentOS 等发行版相继推出安全更新 (例如 Debian 的 DSA-3032、Ubuntu 的 USN-2362-1 等)¹⁵。Linux 系统管理员应立即使用包管理器升级 Bash, 如在 CentOS/RedHat 上执行 `yum update bash`, 在 Debian/Ubuntu 上执行 `apt-get update bash`^{16 15}。
- **macOS 平台**: 苹果公司于 2014 年 9 月 29-30 日发布了 OS X Bash 补丁, 更新了 Mavericks、Mountain Lion 和 Lion 系统中的 Bash 版本^{17 18} (Yosemite 发布后也推送了更新)。用户可通过“软件更新”获取补丁^{17 18}。
- **检测与验证**: 补丁应用后, 应验证系统是否仍存在漏洞。常用验证命令示例:
 - 执行 `env x='()' { :;;; echo OOPS' bash -c :`, 如果系统易受影响, 则会输出“OOPS”, 否则无输出¹⁹。
 - 执行 `env x='()' { :;;; echo VULN' bash -c "echo"`, 若输出“VULN”, 则表示存在漏洞 (Fudan 报告提供的示例)²⁰。
 - 也可使用问答社区推荐的测试命令: `env x='()' { :;;; echo vulnerable' bash -c "echo test"`, 若在输出中出现“vulnerable”字样, 即表明 Bash 未打上修复补丁^{19 20}。
- **其他缓解方法**: 在等待官方补丁或无法立即升级时, 可使用临时措施降低风险, 如禁用不必要的 CGI 功能、将 `/bin/sh` 链接指向不含漏洞的 shell (如 `dash`)、修改 SSH 配置以禁止 ForceCommand 执行等。但这些方法不可替代补丁升级的必要性。

总之，唯一可靠的修复方法是升级到厂商提供的已修复 Bash 版本¹⁶¹⁵。在补丁发布后一天内，多个安全机构（如 CISA、US-CERT 等）都发布了紧急公告，敦促管理员立即更新系统以防被攻击。

后续影响与衍生漏洞

Shellshock 暴露后几天内即被广泛利用并引起安全界高度关注。攻击者在首次披露后几个小时内即开始扫描互联网并构建僵尸网络进行分布式攻击¹⁴。安全社区也迅速发现与 CVE-2014-6271 相关的多种后续缺陷：原始补丁存在绕过方法，导致出现 CVE-2014-7169（等同于补丁绕过漏洞）；与此同时还发现了 CVE-2014-6277、CVE-2014-6278、CVE-2014-7186、CVE-2014-7187 等多项 Shellshock 系列漏洞²¹。Bash 维护者 Chet Ramey 先后发布了新一轮补丁来修复这些次生问题²¹。可以说，初始漏洞和衍生问题共同构成了一个漏洞簇（Shellshock 家族）。

在社区响应方面，Shellshock 漏洞引发了媒体和机构的高度关注。众多博客与安全研究报告对其危害进行了阐述，SecurityFocus、CloudFlare、TrendMicro 等先后发布技术分析和防护建议²²²³。官方机构如 NVD、CISA 更新其公告，列入“已知利用漏洞”名单，敦促快速打补丁⁴²⁴。由于漏洞利用门槛低（只需在环境变量中加上函数定义字符串即可触发），其引发的恐慌程度堪比 Heartbleed，并成为了安全演习和研究的重点案例。研究人员还提出了对 shell 参数解析规则进行严格化的方案，以避免未来出现类似的环境变量注入问题。

参考资料： 以上内容综合参考了 NVD/CVE、安天实验室报告、CloudFlare 安全博客、红帽通告、Fudan 漏洞预警等公开文档²⁷²⁵¹⁰¹⁹。

¹ ⁷ ¹⁴ ²¹ Shellshock (software bug) - Wikipedia

[https://en.wikipedia.org/wiki/Shellshock_\(software_bug\)](https://en.wikipedia.org/wiki/Shellshock_(software_bug))

² ⁴ ⁵ NVD - cve-2014-6271

<https://nvd.nist.gov/vuln/detail/cve-2014-6271>

³ ⁶ ⁸ ¹⁵ ²⁰ ²⁵ Shellshock漏洞预警

<https://icampus.fudan.edu.cn/42/a3/c33375a410275/page.htm>

⁹ exploit-db.com

<https://www.exploit-db.com/docs/english/48112-the-shellshock-attack-%5Bpaper%5D.pdf?ref=benheater.com>

¹⁰ ²² ²³ Inside Shellshock: How hackers are using it to exploit systems

<https://blog.cloudflare.com/inside-shellshock/>

¹¹ bash - how can shellshock be exploited over SSH? - Unix & Linux Stack Exchange

<https://unix.stackexchange.com/questions/157477/how-can-shellshock-be-exploited-over-ssh>

¹² ¹³ Bash远程代码执行漏洞“破壳”（CVE-2014-6271）分析 | 下一代反病毒引擎创造者

<https://www.antiy.com/response/bash.html>

¹⁶ ²⁴ linux - Has CVE-2014-6271 Shell Shock been mitigated completely what is the latest? - Information Security Stack Exchange

<https://security.stackexchange.com/questions/68234/has-cve-2014-6271-shell-shock-been-mitigated-completely-what-is-the-latest>

¹⁷ Apple Releases OS X Bash Update to Fix 'Shellshock' Security Flaw in Mavericks, Mountain Lion, and Lion - MacRumors

<https://www.macrumors.com/2014/09/29/apple-os-x-mavericks-bash-update/>

¹⁸ Apple Releases Patches for Shellshock Bug – Krebs on Security

<https://krebsonsecurity.com/2014/09/apple-releases-patches-for-shellshock-bug/>

19 bash - Explanation of the command to check shellshock - Ask Ubuntu

<https://askubuntu.com/questions/529511/explanation-of-the-command-to-check-shellshock>